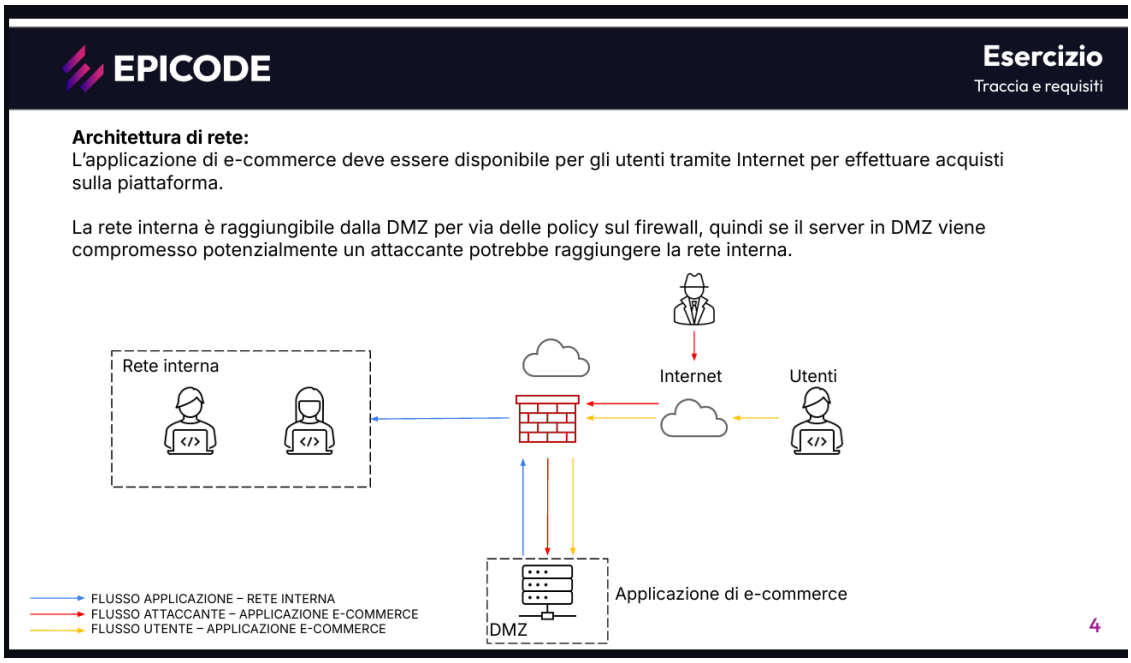
W20D4 PRATICA CORSO CSPT

ALUNNO: ORAZIO MORGILLO

TRACCIA:

ANALIZZARE LA FIGURA E RISPONDERE AI QUESITI DELLA SECURITY OPERATION



Dalla figura notiamo che l'applicazione e-commerce si trova in DMZ ed è collegata alla rete interna tramite policy firewall. Questo rende la DMZ un punto critico poiché una compromissione del server può diventare il punto di partenza di un hacker per raggiungere tutti gli altri sistemi.
Una DMZ (zona demilitarizzata) è una zona di rete che protegge e aggiunge un ulteriore livello di sicurezza alla rete locale interna dal traffico non attendibile. Praticamente, viene usata in modo da non pubblicare direttamente la rete interna aziendale.
Nell'esempio abbiamo tre flussi: il traffico degli utenti verso l'e-commerce; il traffico dalla web app verso la rete interna ed il traffico dell'hacker da internet verso il server esposto.

1) Azioni preventive: quali azioni preventive potrebbero essere implementate per difendere l'app web da attacchi SQLi oppure XSS da parte di un hacker?

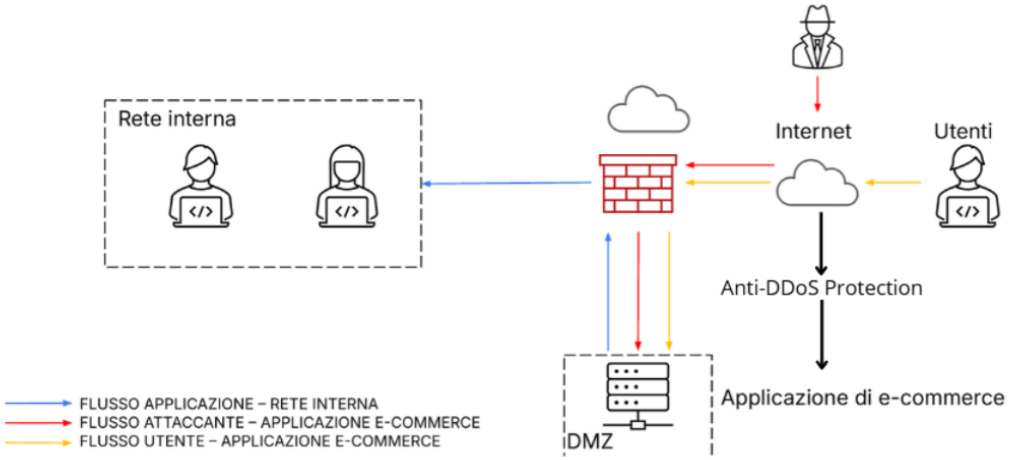
La SQLi è un attacco in cui l'aggressore inserisce degli input malevoli in dei campi dell'applicazione per alterare le query SQL eseguite dal server, che hanno obiettivi quali ad esempio la modifica o cancellazione dei dati.
La XSS, invece, è un attacco in cui il codice malevolo viene iniettato in una pagina web e poi eseguito nel browser della macchina attaccata, con possibile furto di cookie o manipolazioni dell'interfaccia HTML.
Le azioni preventive contro la SQLi potrebbero essere l'introduzione di web Application firewall (WAF), ossia un dispositivo fisico o cloud che analizza il traffico in ingresso e filtra le richieste. Oppure introdurre delle query personalizzate che separano il codice SQL dall'input dell'utente, cioè il dato fornito dal'utente non viene mai interpretato come istruzione SQL ma solo come valore.
Le contromisure contro XXS potrebbero essere l'utilizzo di librerie dedicate per rimuovere o neutralizzare contenuti HTML non ammessi nei campi di testo liberi o accettare solo dati nel formato richiesto.

La figura potrebbe essere modificata aggiungendo una WAF tra internet e applicazione e-commerce in DMZ e aggiungere regole firewall più restrittive tra DMZ e rete interna consentendo solo flussi strettamente indispensabili.

2) impatti sul business: l'app web subisce un attacco di tipo DDoS dall'esterno che rende l'app non raggiungibile per 10 minuti.
Calcolare l'impatto sul business considerando che in media ogni minuto gli utenti spendono €1.500 sulla piattaforma. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica.

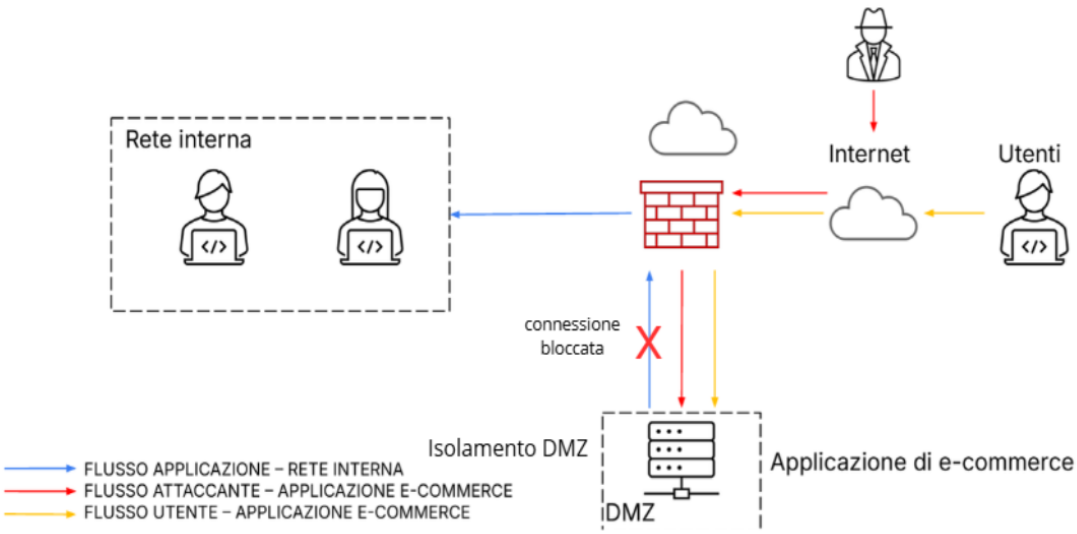
Un DDoS (distribuite denial of service) è un attacco in cui un grande numero di dispositivi compromessi inondano di richieste o traffico il sistema bersaglio, saturando le risorse disponibili fino a rendere il servizio irraggiungibile per gli utenti legittimi.

Se ogni 10 minuti vengono spesi in media €1.500, l'impatto sul business sarà di €15.000 (10x1.500). Quindi questo è il danno diretto stimato delle vendite dovuto all'irraggiungibilità del sito e-commerce.
Oltre al danno puramente economico, tuttavia, potrebbero esserci anche danni di reputazione del brand o del sito (perdite di fiducia e di conseguenza di clienti causate dal problema insorto), danni indiretti ossia aumento delle richieste di reso/rimborso, sovraccarico dell'assistenza clienti, reclami.
In questo caso, l'azione principale potrebbe essere attivare un servizio anti-DDoS specializzato, ossia dei servizi che assorbono o filtrano il traffico malevolo prima che raggiunga il server; oppure attivare regole firewall intelligenti per bloccare il traffico anomalo proveniente da sorgenti sospette.
Introdurre sistemi IDS/IPS: rilevano anomalie nel traffico e possono attivare contromisure automatiche.



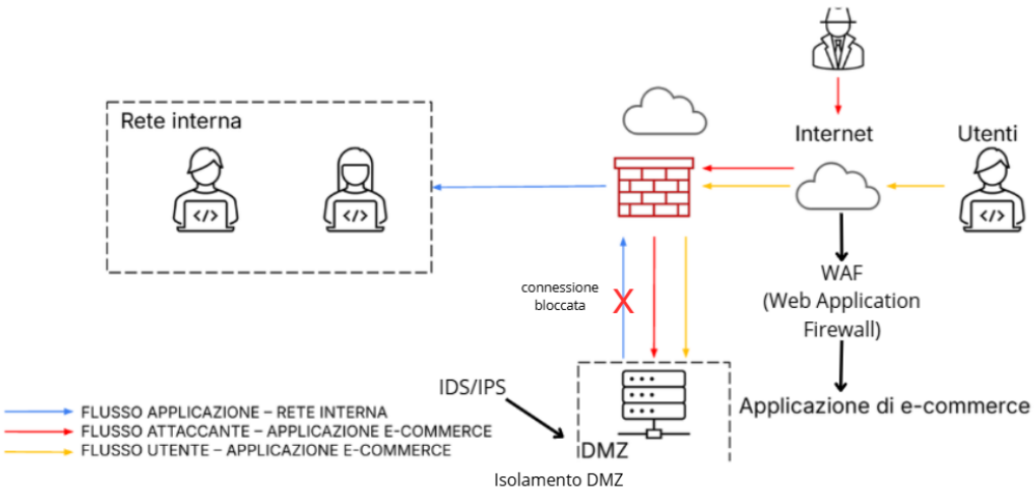
3) Response: l'app web viene infettata da un malware.
La priorità è che quest'ultimo non si protragga sulla rete, mentre non siamo interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infetta.

Un malware è un software creato per infettare una macchina. Nel nostro caso, il malware infetta il server web in DMZ che è il sistema più esposto.
La priorità non è rimuovere l'accesso dell'attaccante alla nostra macchina ma evitare che il malware infetti tutto il resto della rete interna.
Bisogna attuare un'operazione di contenimento, ossia isolare il server e-commerce mettendolo in quarantena di rete rispetto alla rete interna. Questo significa ridurre significativamente le comunicazioni tra la DMZ e la rete interna tramite regole firewall molto stringenti.



4) unire i punti 1 e 4

Unendo le due architetture, ci garantiamo che il traffico malevolo venga filtrato già prima di raggiungere l'applicazione tramite il WAF e il sistema anti-DDoS.
Anche se il codice malevolo arrivasse all'applicazione, tutte le difese applicate lo neutralizzerebbero e anche se il server fosse compromesso, la segmentazione e le stringenti regole di firewall impedirebbero che l'attaccante giunga alla rete interna.
Il monitoraggio continuo permette di rilevare anomalie in tempo reale e attivare il containment.



5) la modifica più aggressiva potrebbe essere il sistema anti-DDoS spiegata già nel punto 2.

CONCLUSIONI:

L'obiettivo dell'esercizio era quello di analizzare e trovare le migliori soluzioni su un caso di una architettura "fragile" che viene attaccata da un hacker o che potrebbe essere attaccata.
Tutte le modifiche effettuate sono in ambito di Security operation e servono per avere un sistema che risponda in modo efficace a tutte le eventuali problematiche che possono riguardare un sistema anche quotidianamente.